

Milestone: Major project event.

Mobile device: A portable computing and communications device with information-storage capability. Examples include notebook and laptop computers, cellular telephones and smart phones, tablets, digital cameras, and audio recording devices.

Mobile financial services: A financial institution's use of mobile devices to provide products and services to its customers.

National Institute of Standards and Technology (NIST): An agency of the U.S. Department of Commerce that works to develop and apply technology, measurements, and standards. NIST developed a voluntary cybersecurity framework based on existing standards, guidelines, and practices for reducing cyber risks to critical infrastructures.

Network: Two or more computer systems that are connected to share information, software, and hardware.

Operating system: A system that supports and manages software applications. Operating systems allocate system resources, provide access and security controls, maintain file systems, and manage communications between end users and hardware devices.

Operational IT plan: Typically, the plans that are made by front-line, or low-level, IT managers. Operational IT plans are focused on the specific procedures and processes that implement the larger strategic plan.

Operational risk: The risk of failure or loss resulting from inadequate or failed processes, people, or systems.

Penetration test: The process of using approved, qualified personnel to conduct real-world attacks against a system to identify and correct security weaknesses before they are discovered and exploited by others.

Preventive control: A mitigating technique designed to prevent an event from occurring.

Principle of least privilege: The security objective of granting users only the access needed to perform official duties.

Project: A task involving the acquisition, development, or maintenance of a technology product.

Project management: Planning, monitoring, and controlling an activity.

Residual risk: The amount of risk remaining after the implementation of controls.

Resilience: The ability of an institution to recover from a significant disruption and resume critical operations.

Risk: The potential that events, expected or unanticipated, may have an adverse effect on a financial institution's earnings, capital, or reputation.

Risk identification: The process of determining risks and existing safeguards. It generally includes inventories of systems and information necessary to operations and defines the potential threats to systems and operations.

Risk management: The total process required to identify, control, and minimize the impact of uncertain events. The objective of a risk management program is to reduce risk and obtain and maintain appropriate management approval at pre-defined stages in the life cycle.

Risk measurement: A process of determining the likelihood of an adverse event or threat occurring and the potential impact of such an event on the institution. The result of risk measurement is the prioritization of potential risks based on severity and likelihood of occurrence.

Risk mitigation: The process of reducing risks through the introduction of specific controls and risk transfer. It includes the implementation of appropriate controls to reduce the potential for risk and bring the level of risk in line with the board's risk appetite.

Scenario analysis: The process of analyzing possible future events by considering alternative possible outcomes.

Scorecard: A dashboard of performance measures.

Security breach: A security event that results in unauthorized access of data, applications, services, networks, or devices by bypassing underlying security mechanisms.

Security event: An event that potentially compromises the confidentiality, integrity, availability, or accountability of an information system.

Security posture: The security status of an enterprise's networks, information, and systems based on information assurance resources (e.g., people, hardware, software, and policies) and capabilities in place to manage the defense of the enterprise and to react as the situation changes.

Sensitive customer information: A customer's name, address, or telephone number, in conjunction with the customer's social security number, driver's license number, account number, credit or debit card number, or a personal identification number or password that would permit access to the customer's account. Sensitive customer information also includes any combination of components of customer information that would allow someone to log on to or access the customer's account, such as user name and password or password and account number.

Service level agreement (SLA): Formal documents between an institution and its third-party provider that outline an institution's predetermined requirements for a service and establish

incentives to meet, or penalties for failure to meet, the requirements. SLAs should specify and clarify performance expectations, establish accountability, and detail remedies or consequences if performance or service quality standards are not met.

Social engineering: A general term for trying to trick people into revealing confidential information or performing certain actions.

Systems administration: The process of maintaining, configuring, and operating computer systems.

Tactical plan: Typically, a short-term plan that establishes the specific steps needed to implement a company's strategic plan.

Telecommunications: The exchange of information over significant distances by electronic means.

Third-party provider: Any type of company, including affiliated entities, nonaffiliated entities, and alliances of companies providing products and services to a financial institution. Other terms used to describe service providers include subcontractors, external service providers, application service providers, and outsourcers. Also called a third-party service provider.

Third-party relationship: Any business arrangement between a financial institution and another entity, by contract or otherwise.

Threat intelligence: The acquisition and analysis of information to identify, track, and predict cyber capabilities, intentions, and activities that offer courses of action to enhance decision-making.

Total cost of ownership (TCO): The true cost of ownership of a computer or other technology system that includes: original cost of the computer and software; hardware and software upgrades; maintenance; technical support; and training.

Virus: Malicious code that replicates itself within a computer.

Vulnerability: A hardware, firmware, or software flaw that leaves an information system open to potential exploitation; a weakness in automated system security procedures, administrative controls, physical layout, internal controls, etc., that could be exploited to gain unauthorized access to information or to disrupt critical processing.

Appendix C: References

Laws

- 12 USC 1464(d), Home Owners' Loan Act
- 12 USC 1867(c), Bank Service Company Act
- 12 USC 1882, Bank Protection Act
- 15 USC 6801 and 6805(b), Gramm–Leach–Bliley Act
- 18 USC 1030, Computer Fraud and Abuse Act

Federal Reserve

Regulations

- 12 CFR 208, appendix D-2, “Interagency Guidelines Establishing Information Security Standards”
- 12 CFR 211.5 and 211.24 (i), Protection of Customer and Consumer Information
- 12 CFR 225, appendix F, “Interagency Guidelines Establishing Information Security Standards”

Guidance

- SR Letter 13-19, “Guidance on Managing Outsourcing Risk” (December 5, 2013)
- SR Letter 11-9, “Interagency Supplement to Authentication in an Internet Banking Environment” (June 29, 2011)
- SR Letter 05-23, “Unauthorized Access to Customer Information” (December 1, 2005)
- SR Letter 05-19, “Interagency Guidance on Authentication in an Internet Banking Environment” (October 13, 2005)
- SR Letter 01-15, “Standards for Safeguarding Customer Information” (May 31, 2001)
- SR Letter 00-17, “Guidance on the Risk Management of Outsourced Technology Services” (November 30, 2000)
- SR Letter 99-8, “Uniform Rating System for Information Technology” (March 31, 1999)
- SR Letter 98-9, “Assessment of Information Technology in the Risk-Focused Frameworks for the Supervision of Community Banks and Large Complex Banking Organizations” (April 20, 1998)

Federal Deposit Insurance Corporation

Regulations

- 12 CFR 364, appendix A, “Interagency Guidelines Establishing Standards for Safety and Soundness”
- 12 CFR 364, appendix B, “Interagency Guidelines Establishing Information Security Standards”

Guidance

- FIL-13-2015, “FFIEC Joint Statements on Destructive Malware and Compromised Credentials” (March 30, 2015)
- FIL-21-2014, “Webinar on Senior Management’s Role in Cybersecurity” (April 25, 2014)
- FIL-11-2014, “Distributed Denial of Service Attacks” (April 2, 2014)
- FIL-13-2014, “Technology Outsourcing Information Tools for Community Bankers” (April 7, 2014)
- FIL-46-2012, “Supervision of Technology Service Providers and Outsourcing Technology Services” (November 6, 2012)
- FIL-44-2008, “Third Party Risk: Guidance for Managing Third Party Risk” (June 6, 2008)
- FIL-6-2008, “Interagency Statement on Pandemic Planning: Guidance for Minimizing a Pandemic’s Potential Adverse Effect” (February 6, 2008)
- FIL-52-2006, “Foreign-Based Third Party Service Providers: Guidance on Managing Risks in These Outsourcing Relationships” (June 21, 2006)
- FIL-25-2006, “Influenza Pandemic: Interagency Advisory” (March 15, 2006)
- FIL-121-2004, “Guidance on Developing an Effective Computer Software Evaluation Program to Assure Quality and Regulatory Compliance” (November 16, 2004)
- FIL-103-2004, “Interagency Information Brochure on Internet Phishing Scams” (Sept 13, 2004)
- FIL-43-2003, “Computer Software Patch Management” (May 29, 2003)
- FIL-50-2001, “Bank Technology Bulletin on Outsourcing” (June 4, 2001)
- FIL-49-99, “Required Notification for Compliance with the Bank Service Company Act” (June 3, 1999)

National Credit Union Administration

Regulations

- 12 CFR 721, “Federal Credit Union Incidental Powers Activities”
- 12 CFR 748, “Security Program, Report of Crime and Catastrophic Act, Bank Secrecy Act Compliance,” and appendix A, “Guidelines for Safeguarding Member Information”
- 12 CFR 741, “Requirements for Insurance”
- 12 CFR 740, “Advertising”

Guidance

- NCUA Letter to Credit Unions 02–CU–17, “E-Commerce Guide for Credit Unions” (December 2002)
- NCUA Letter to Credit Unions 01–CU–20, “Due Diligence Over Third–Party Service Providers” (November 2001)
- NCUA Letter to Credit Unions 00–CU–11, “Risk Management of Outsourced Technology Services (with Enclosure)” (December 2000)

Office of the Comptroller of the Currency

Regulations

- 12 CFR 30, appendix A, “Interagency Guidelines Establishing Standards for Safety and Soundness”
- 12 CFR 30, appendix B, “Interagency Guidelines Establishing Information Security Standards”

Guidance

- OCC Bulletin 2015–20, “Cybersecurity: Destructive Malware Joint Statement” (March 30, 2015)
- OCC Bulletin 2015–19, “Cybersecurity: Cyber Attacks Compromising Credentials Joint Statement” (March 30, 2015)
- OCC Bulletin 2015–9, “FFIEC Information Technology Examination Handbook: Strengthening the Resilience of Outsourced Technology Services, New Appendix for Business Continuity Planning Booklet” (February 6, 2015)
- OCC Bulletin 2014-45, “Heightened Standards for Large Banks; Integration of 12 CFR 30 and 12 CFR 170: Final Rules and Guidelines”
- OCC Bulletin 2014–53, “Cybersecurity: Cybersecurity Assessment General Observations and Statement” (November 3, 2014)
- OCC Bulletin 2013–29, “Third-Party Relationships: Risk Management Guidance” (October 30, 2013)
- OCC Bulletin 2006–26, “Disaster Planning: Hurricane Katrina—Lessons Learned” (June 15, 2006)
- OCC Bulletin 2006–12, “Influenza Pandemic: Interagency Advisory” (March 15, 2006)
- OCC Bulletin 2004–47, “FFIEC Guidance: Risk Management for the Use of Free and Open Source Software” (October 27, 2004)
- OCC Bulletin 2003–14, “Interagency White Paper on Sound Practices to Strengthen the Resilience of the U.S. Financial System” (April 8, 2003)
- OCC Bulletin 1998–3, “Technology Risk Management: Guidance for Bankers and Examiners” (February 4, 1998)

Other References

- FDIC FIL-28-2015 “Cybersecurity Assessment Tool” (July 2, 2015)
- SR Letter 15-9, “FFIEC Cybersecurity Assessment Tool for Chief Executive Officers and Boards of Directors” (July 2, 2015)
- OCC Bulletin 2015-31, “FFIEC Cybersecurity Assessment Tool” (June 30, 2015)
- Basel Committee on Banking Supervision, “[Sound Practices for the Management and Supervision of Operational Risk](#)” (February 2003)
- [ISACA](#) Control Objectives for Enterprise IT Governance (CoBIT)